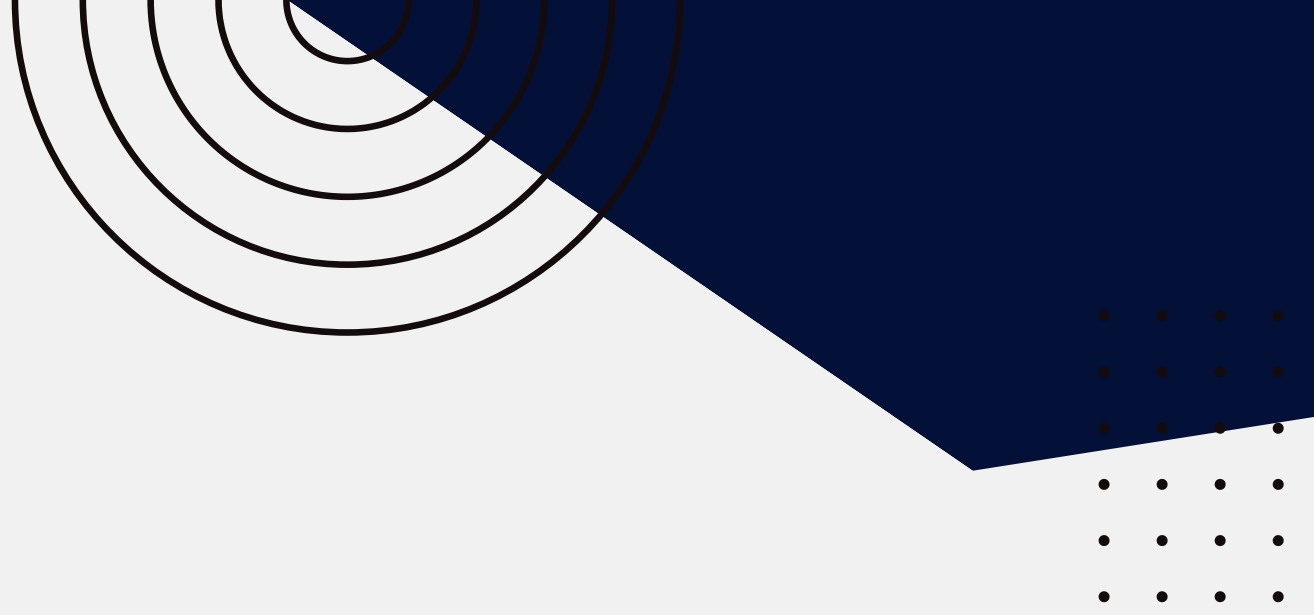
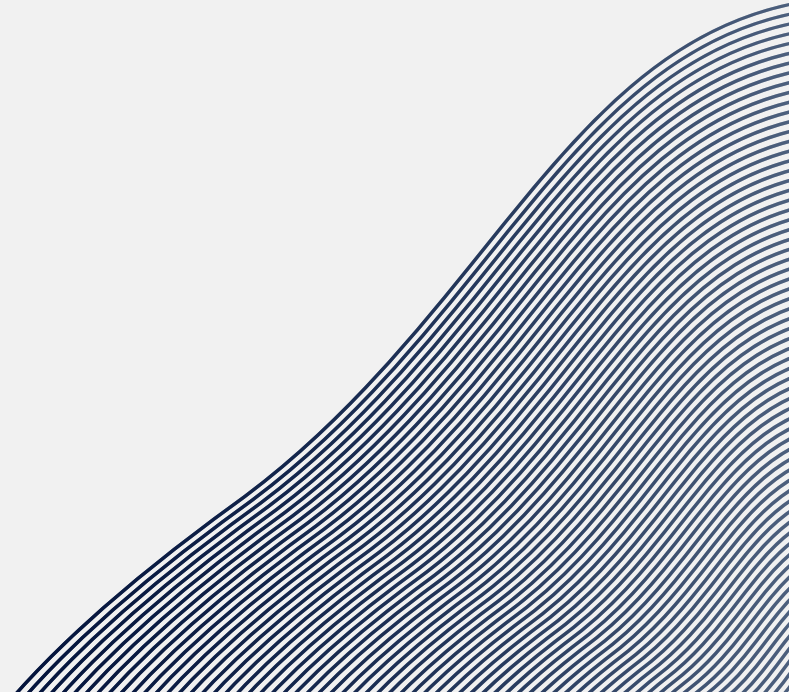
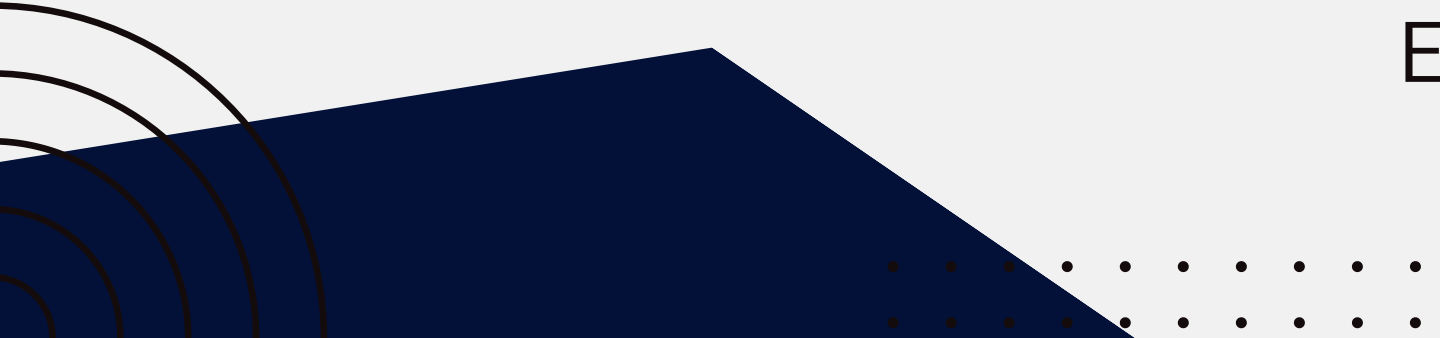
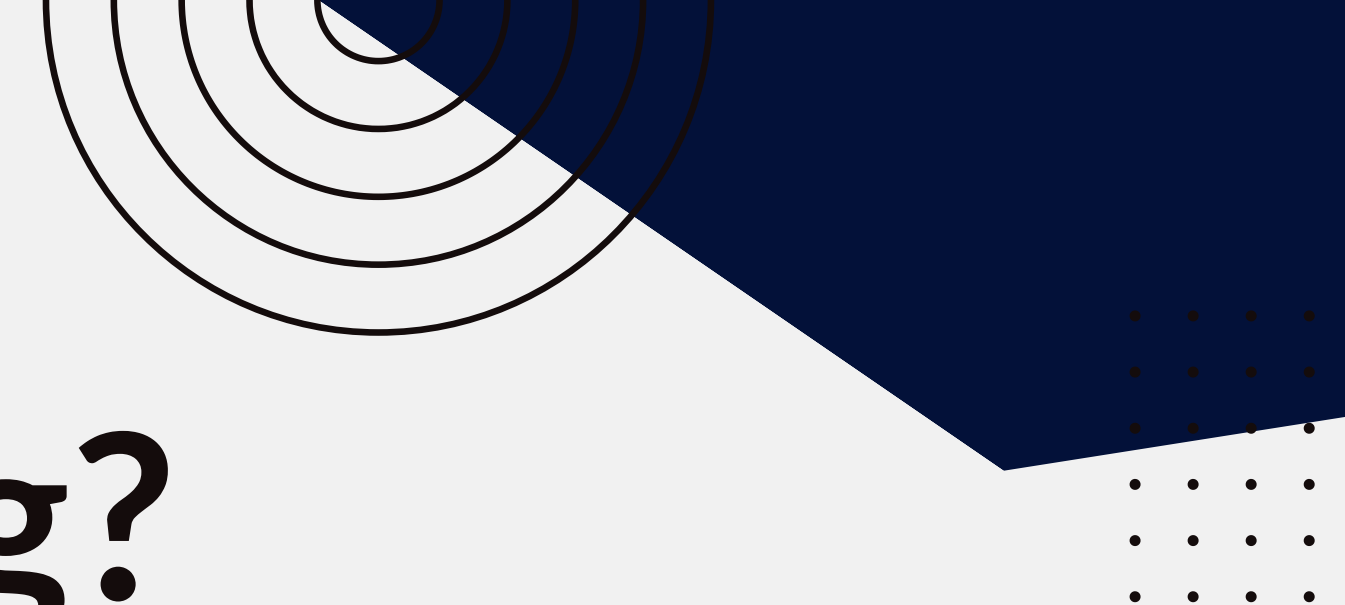




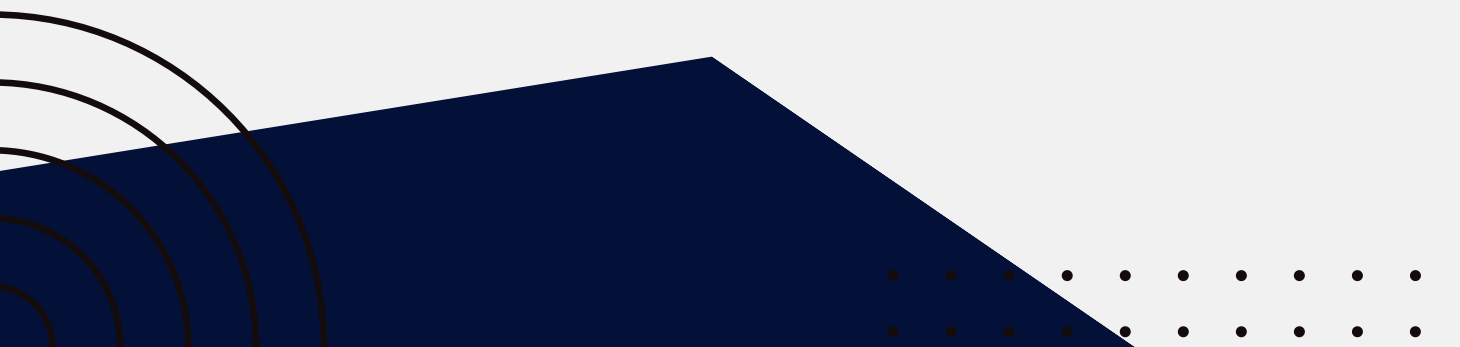
THREAT HUNTING

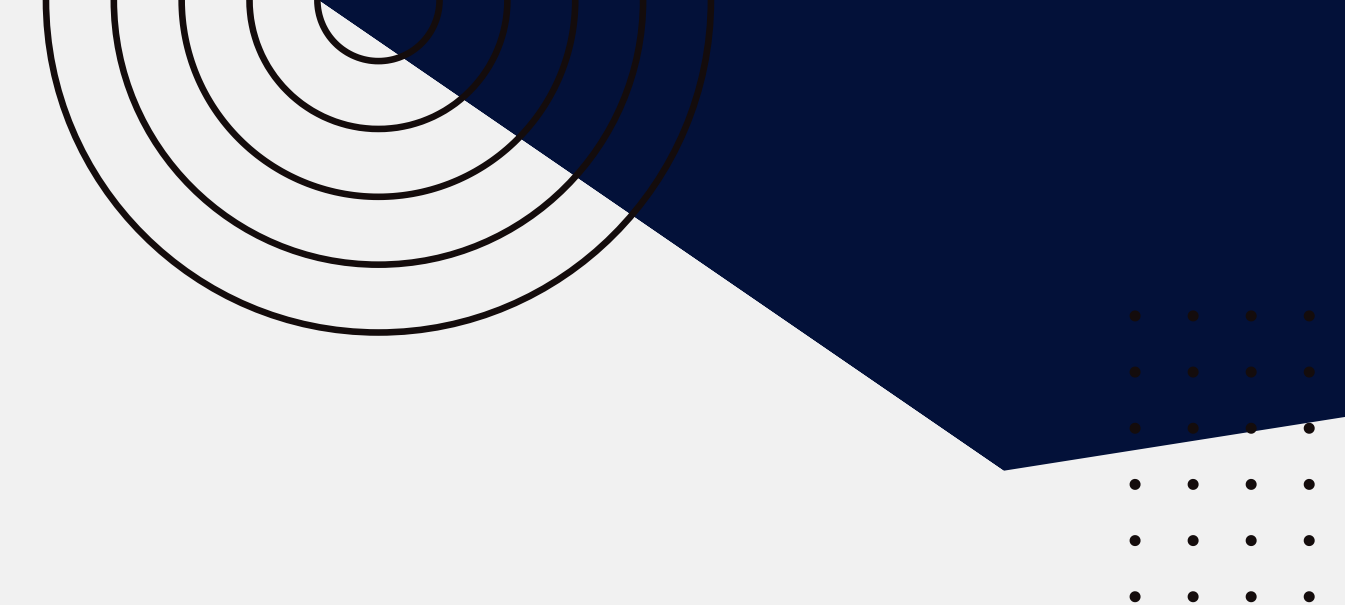
Eng.Farah Abuelazm



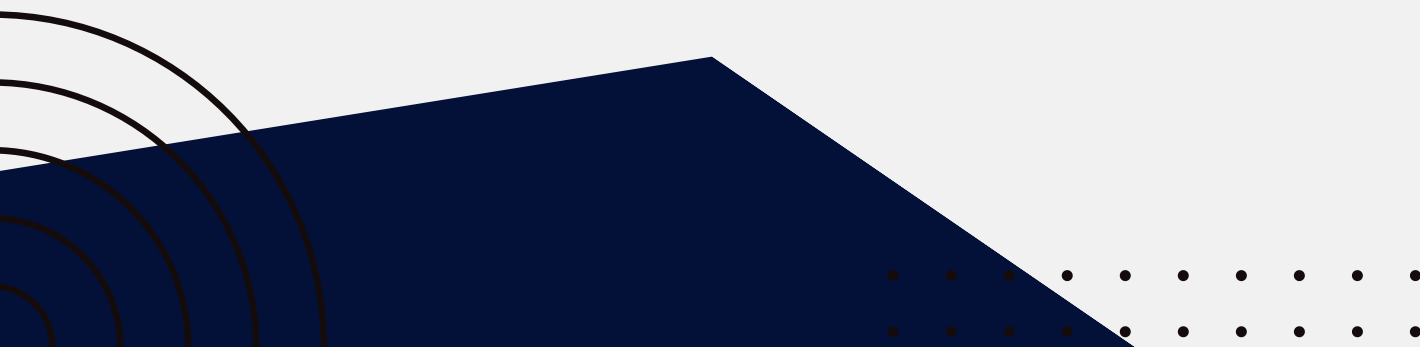


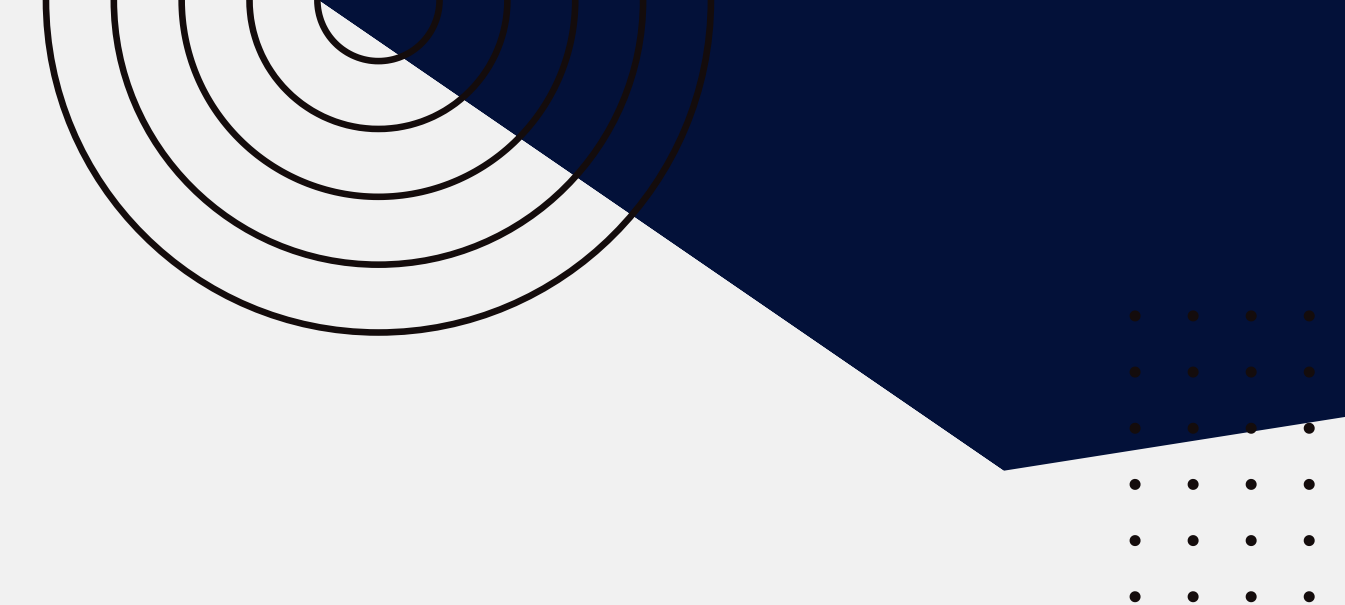
What is Threat Hunting?

- It is a proactive approach to securing your organization's systems. It is the process of actively looking for signs of malicious activity in enterprise networks, without prior knowledge of those signs.
 - It allows you to uncover threats on your network without signatures or known indicators of compromise (IOCs).
- 



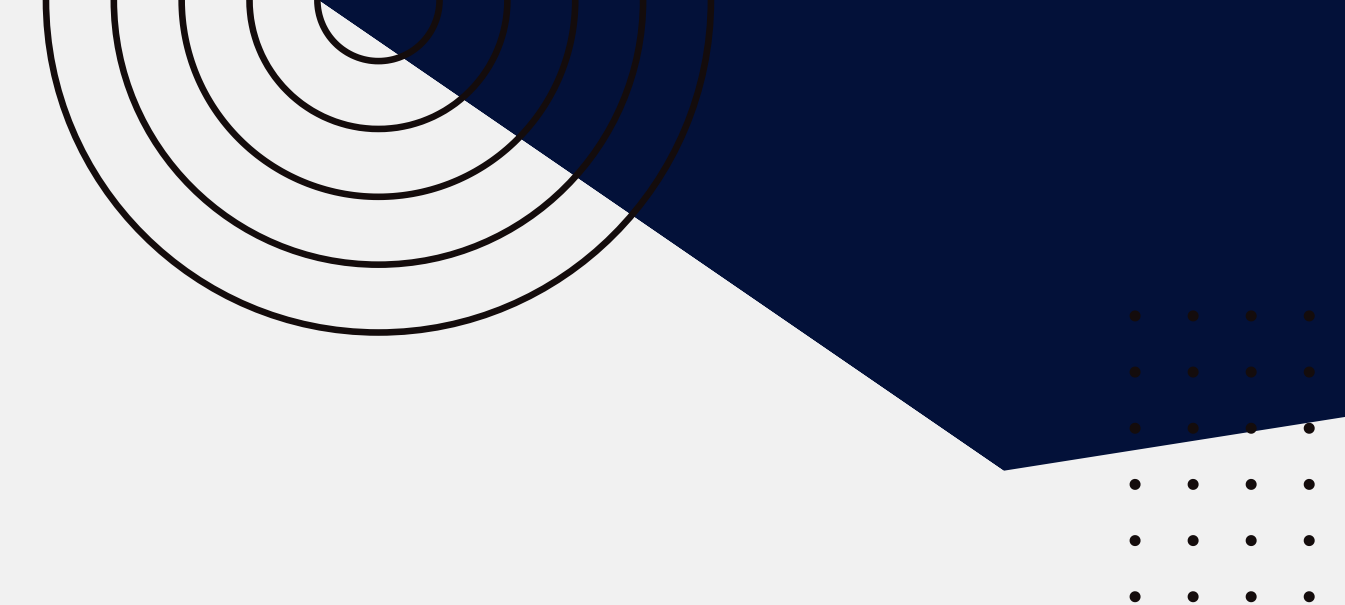
Threat Hunting Goal:

- The main objective of threat hunting is to minimize the time attackers remain undetected.
 - By spotting intrusions at an early stage, organizations can remove malicious activity from their systems and networks before attackers accomplish their goals.
 - Detecting threats early also limits the extent of damage, enabling quicker, more efficient, and much less expensive remediation.
- 
-

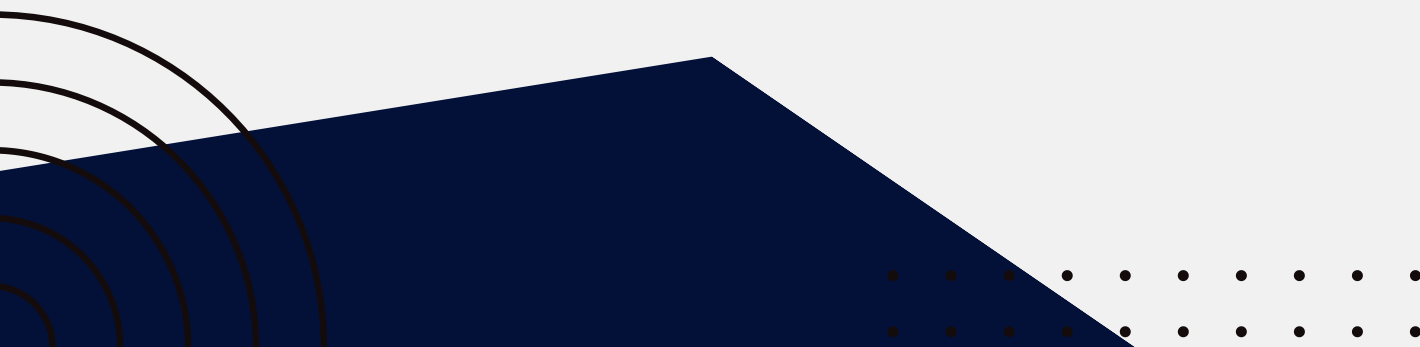


The Hunt Team:

- Mainly composed of people with wide range of Experience in several parts like :
 - **Security:** Common adversary methods, incident response, and attack/malware detection tools.
 - **Threat Detection:** Techniques and tools used in red teaming, pen testing, and by attackers.
 - **IT Operations:** Understanding applications, networks, enterprise systems, and OS workings.
 - **Communication:** Effective coordination with hunters, security teams, management, and HR.
- 



The Hunt Team:

- Some main roles that is preferred to be in Hunting team:
 - **Incident Manager:** Leads investigations, understands business risks from threats, and directs the response team.
 - **Response Analyst:** Analyzes data from multiple sources, documents, and communicates findings.
 - **Malware Analyst:** Uses automated tools to analyze and reverse-engineer malware, creating decoders and utilities for analysts.
 - **Operations Staff:** Supports IT functions with knowledge of systems, networks, and application management.
- 
-

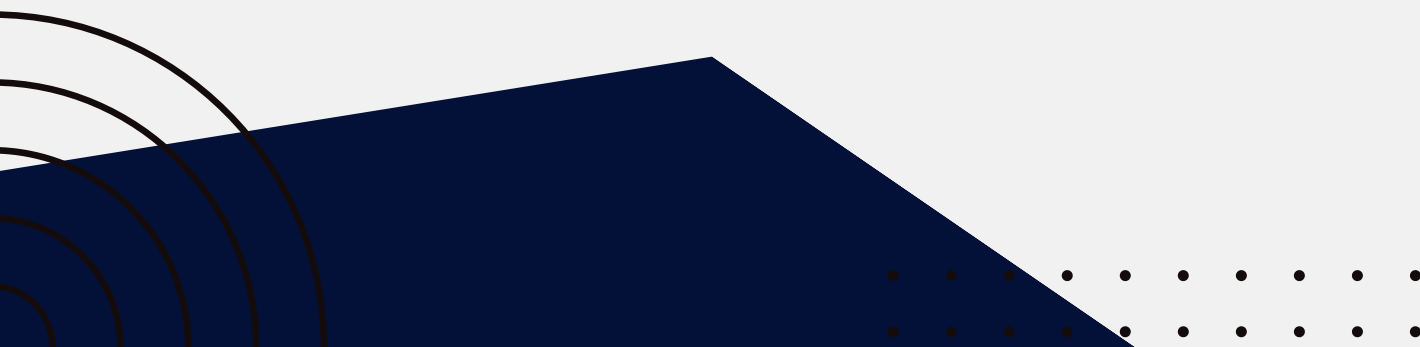


What we are looking for ?

- Hunt teams search for behaviors and evidence of attacker techniques, not just known malware or IOCs (Indicators of Compromise).
- Focus is on uncovering attacker activities that may not yet be recognized.

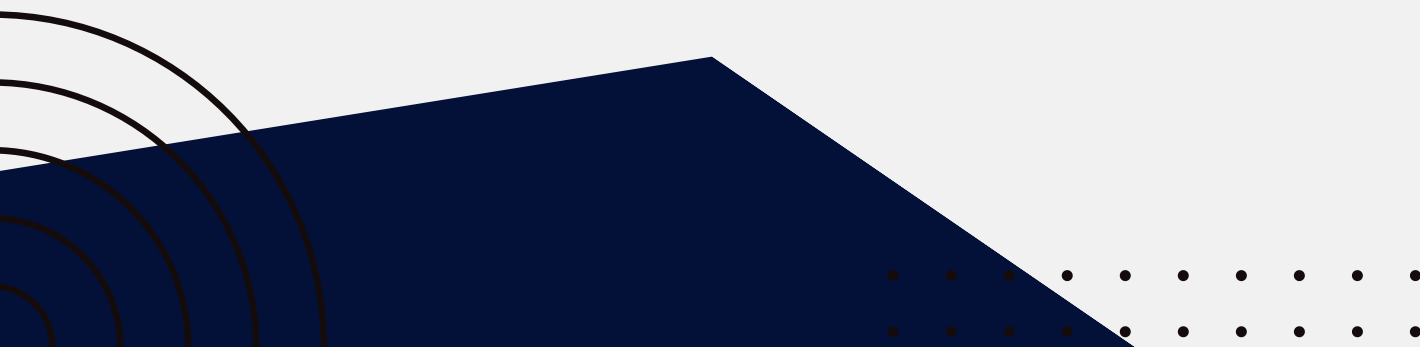


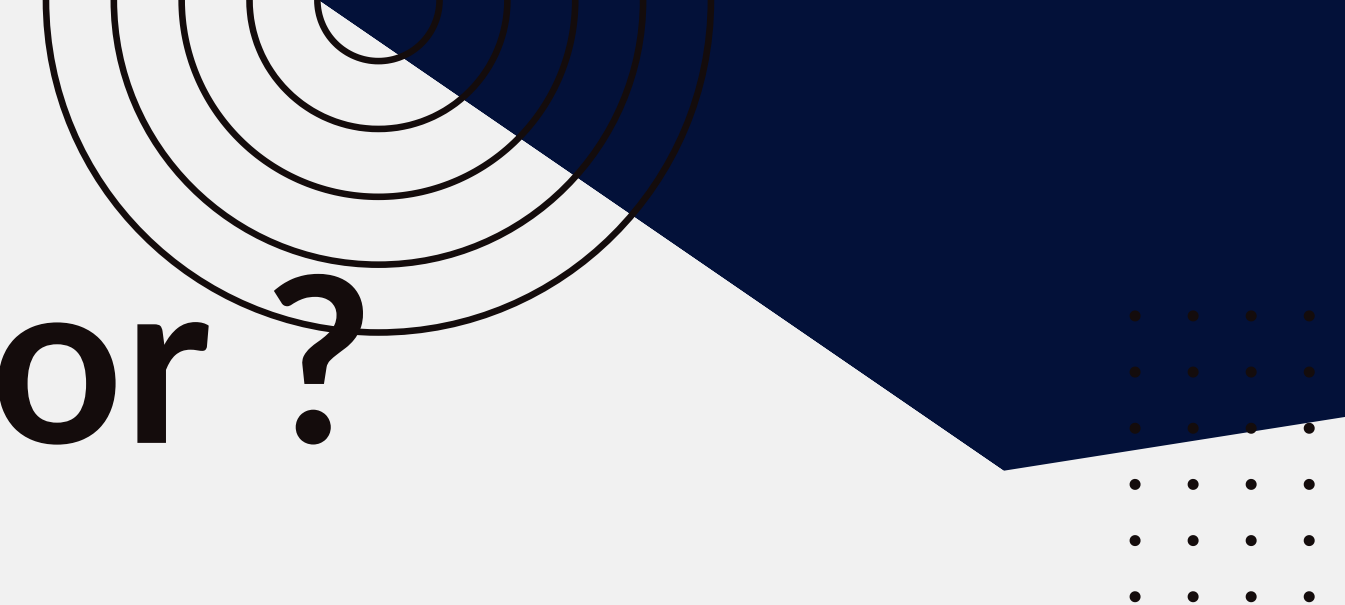
What we are looking for ?

- Using Known Indicators Efficiently
 - Track “known bad” indicators: file hashes, IPs, DNS records.
 - Automate searches to save time and human effort.
 - Treat findings as alerts: triage and feed insights into hunts.
 - Researching Attacker Techniques
 - Study offensive tools, techniques, and procedures (TTPs).
 - Document TTPs in a threat-neutral, industry-aware way.
 - View techniques as skills, tactics as applying those skills.
- 



What we are looking for ?

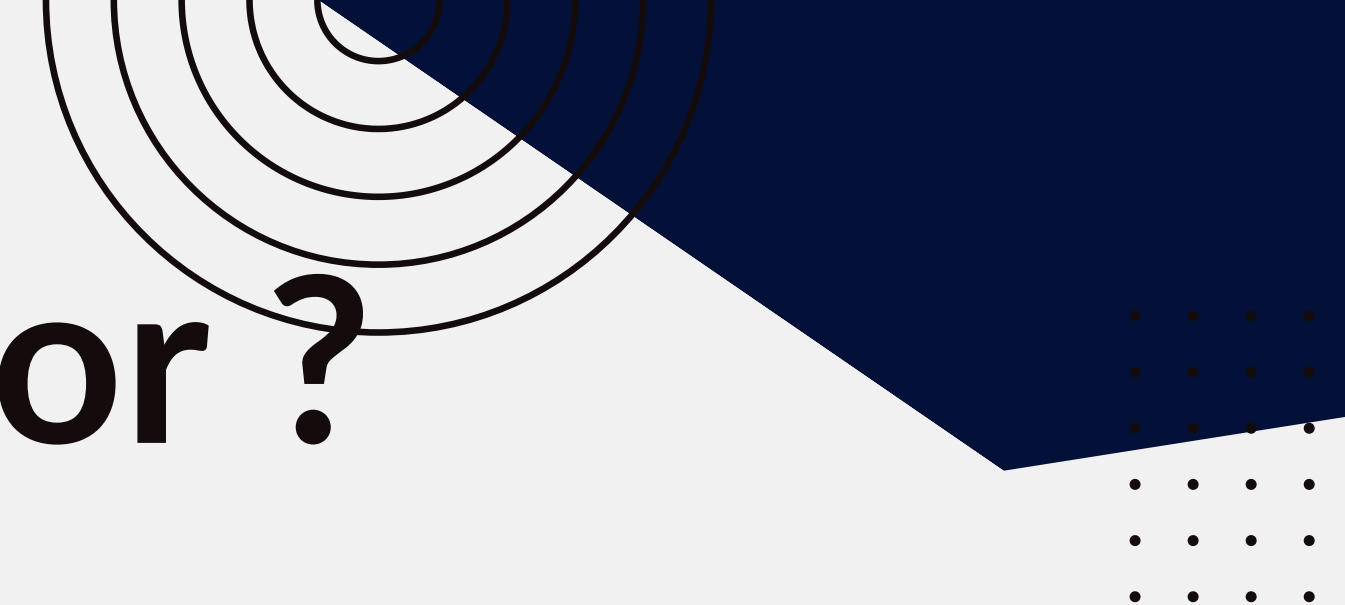
- Understanding Adversaries
 - Common attacker types:
 - Financially motivated actors
 - Hacktivists
 - State-sponsored operators
 - Each has unique goals, targets, and methods.
 - Categories may overlap; attackers often operate without constraints.
- 
-



What we are looking for ?

1. Digital Artifacts & Indicators of Compromise:

- **Filesystem Metadata:** Changes to file creation dates, permissions, or hidden directories
 - Ex: Beyond just "files," we look at timestamps and permissions. Did a system file suddenly change its "last modified" date at 3:00 AM?
- **Network Metadata:** Patterns in DNS queries, outbound responses, and NetFlow data.
 - Ex: We analyze the "phone records" of the network. Who is the server talking to? Are there unusual DNS queries to unknown domains?
- **Application Logs:** Logs and metadata generated by web servers or internal software.
 - Ex: Attackers often hide inside legitimate software (like web servers). We hunt for anomalies in how those applications are behaving.
- **Authentication Records:** Login attempts, credential use, and user account activity.
 - Ex. We track the "keys." Is a user account suddenly logging in from a remote country or at an unusual hour?



What we are looking for ?

1. Digital Artifacts & Indicators of Compromise:

- **Filesystem Metadata:** Changes to file creation dates, permissions, or hidden directories
 - Ex: Beyond just "files," we look at timestamps and permissions. Did a system file suddenly change its "last modified" date at 3:00 AM?
- **Network Metadata:** Patterns in DNS queries, outbound responses, and NetFlow data.
 - Ex: We analyze the "phone records" of the network. Who is the server talking to? Are there unusual DNS queries to unknown domains?
- **Application Logs:** Logs and metadata generated by web servers or internal software.
 - Ex: Attackers often hide inside legitimate software (like web servers). We hunt for anomalies in how those applications are behaving.
- **Authentication Records:** Login attempts, credential use, and user account activity.
 - Ex. We track the "keys." Is a user account suddenly logging in from a remote country or at an unusual hour?

What we are looking for ?

2. Understanding Attacker Tradecraft (analyzing cyber kill chain)

Tradecraft refers to the techniques and procedures used in espionage. In cyber defense, we hunt for the traces left behind by these general procedures.

- **The Adversary's Step-by-Step Procedure**

- **Initial Entry:** Accessing the victim's environment.
- **Establish Control:** Creating Command and Control (C2) channels between internal systems and outside attackers.
- **Privilege Escalation:** Obtaining and leveraging additional system privileges.
- **Reconnaissance:** Investigating internal networks and hosts.
- **Targeting:** Identifying specific data, applications, and systems of interest.
- **Lateral Movement:** Accessing one or more systems across the network.
- **Impact:** Collecting, destroying, or exfiltrating sensitive data to achieve their objectives.

What we are looking for ?

2. Understanding Attacker Tradecraft (analyzing cyber kill chain)

Tradecraft refers to the techniques and procedures used in espionage. In cyber defense, we hunt for the traces left behind by these general procedures.

- **The Adversary's Step-by-Step Procedure**

- **Initial Entry:** Accessing the victim's environment.
- **Establish Control:** Creating Command and Control (C2) channels between internal systems and outside attackers.
- **Privilege Escalation:** Obtaining and leveraging additional system privileges.
- **Reconnaissance:** Investigating internal networks and hosts.
- **Targeting:** Identifying specific data, applications, and systems of interest.
- **Lateral Movement:** Accessing one or more systems across the network.
- **Impact:** Collecting, destroying, or exfiltrating sensitive data to achieve their objectives.

Categorizinng the Unknown

1. Prevalence (The "Odd One Out"):

- Sophisticated attacks usually affect only a small number of systems.
- Hunter Logic: If a file is on 85% of systems, it's likely benign software. If it's only on 2%, it might be a successful phishing campaign.

2. Recentness (The "New Arrival"):

- Attacks that are currently active are the highest priority.
- Hunter Logic: A binary installed three days ago is more suspicious than one installed three years ago.

3. Patterns of Behavior:

- Individual actions may look harmless, but together they reveal intent.
- Example: An endpoint connecting to an unknown server at regularly scheduled intervals suggests malware "phoning home".

Categorizing the Unknown

3. Hunting for Anomalies

- Hunters proactively search for departures from standard behavior across the enterprise. These "traces" often indicate an attacker is currently active

Anomalies are like :

- **Unusual Volumes/Frequencies:** Such as uploading 10GB to an external site in under 24 hours or seeing 20 failed logon attempts per minute from one endpoint.
- **Configuration Deviations:** Executable files that aren't on your "golden image" or registry key differences between old and new systems.
- **Naming Conventions:** Hostnames or filenames that do not follow your organization's standard naming rules.

Categorizinng the Unknown

Other places to Hunt for anomalies:

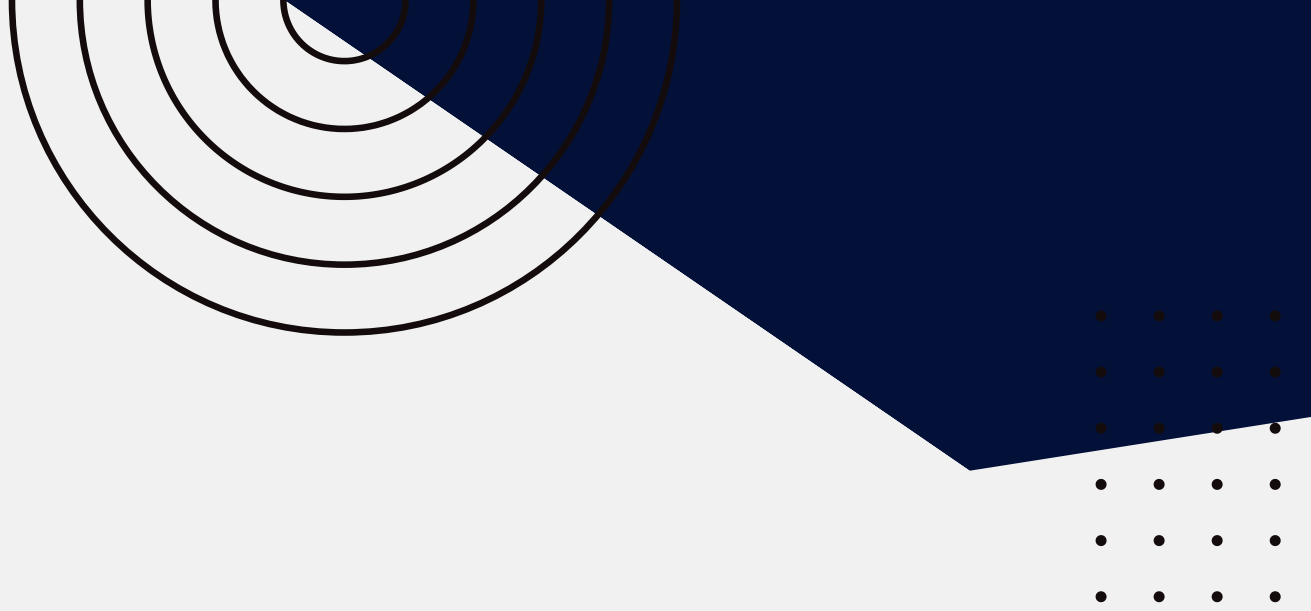
- Run and RunOnce registry keys.
- Windows services
- Image file execution options.
- Application debuggers
- Registered COM servers

Categorizinng the Unknown

4. Building Awareness:

You cannot hunt for "abnormal" behavior if you don't know what "normal" looks like. Before the hunt begins, you must answer:

- **Admin Behavior:** How and from where do our system administrators interact with servers?
- **Privileged Access:** Which accounts are members of privileged groups?
- **Common Tools:** What remote execution tools and UserAgent strings are typical in this environment?
- **Data Flows:** Where is sensitive data stored, and how do users normally access it?
- **Network Baselines:** What are the typical levels of lateral movement (server-to-workstation vs. workstation-to-server)?



Thank You !

